ANCHOR CBS · INSA CYBERSECURITY AUDIT

Document: SRS.md · Generated 11 November 2026

# Software Requirements Specification — SACCO Core Banking / ERP

**System:** CBS General — Web-Based SACCO Core Banking / ERP Back Office
**Document ID:** CBS-SEC-SRS-2026-001 · **Version:** 1.0 · **Date:** 11 November 2026
**Code baseline:** commit `2b23823 (security hardening) + working tree` · **Classification:** Internal / Confidential

## 1. Purpose

This document specifies the functional and non-functional requirements of the SACCO back-office platform implemented in this repository. It is the acceptance baseline for the system **as built** and the reference for the INSA cybersecurity audit. It is not a vendor proposal or a statement of future capability.

## 2. Scope

**In scope:** a browser-based, role-controlled back office covering member onboarding and KYC; membership applications and lifecycle; savings and term/fixed savings (TFS); shares and dividends; loan origination, appraisal, scoring, approval, disbursement, repayment, collateral, restructuring, write-off, recovery, provisioning, and auto-debit assessment; general ledger and chart of accounts; expenses and fixed assets; cash operations; payments; check-off; bank reconciliation; maker-checker approvals; day control and EOD; compliance monitoring; immutable audit trail; SMS/OTP; referrals; notification templates; system operations; administration; dashboards, search, and reports.

**Out of scope:** POS terminals, electronic invoice machines, fiscal printers, card readers, firmware, secure boot, TPM, OTA updates, device management, card acquiring or PAN/CVV storage, customer mobile/web banking, ATM/switch integration, fiscal invoicing, hosting/TLS/disk encryption/backup infrastructure, and third-party certification (ISO 27001, ISO 15408, PCI-DSS).

## 3. Definitions

| Term | Meaning |
|---|---|
| **SACCO / CBS** | Savings and Credit Cooperative / Core Banking System. |
| **TFS** | Term/fixed savings (term deposit) with a fixed term and maturity. |
| **GL / COA** | General Ledger / Chart of Accounts. |

| Term | Meaning |
|---|---|
| **KYC / Fayda ID** | Know Your Customer / Ethiopian national digital identity number. |
| **COB / EOD** | Close of Business / End of Day. |
| **Maker-checker** | One user initiates; a different authorized user approves. |
| **RBAC / MFA / JWT** | Role-Based Access Control / Multi-Factor Authentication / JSON Web Token. |
| **Audit trail** | Append-only, SHA-256 hash-chained record of changes and security events. |

## 4. User Classes and Roles

| Role | Responsibilities | Restrictions |
|---|---|---|
| **ADMIN** | Users, roles, system operations, organization/branch/currency setup, security configuration. | MFA when `REQUIRE_MFA=true`; all actions audited. |
| **MANAGER** | Approvals, oversight, cash operations, reports, audit review. | MFA when enabled; no user/system administration. |
| **TELLER** | Member onboarding, savings transactions, tills, payments. | Read-only audit; no user/system administration; no delete. |
| **CREDIT_OFFICER** | Loan appraisal, scoring, collateral, guarantors, loan groups, recovery. | No GL/user/system administration; no delete. |
| **ACCOUNTANT** | GL, journals, expenses, bank reconciliation, check-off, shares, day control, reports. | No user/system administration; no delete. |
| **AUDITOR** | Read-only review of members, loans, accounting, compliance, and audit trail. | All POST/PUT/PATCH/DELETE denied. |

The server enforces role gates in `SecurityConfig`; the role-filtered navigation is a usability aid, not a security boundary. Fine-grained POST rules now restrict the highest-risk finance/compliance writes, but PUT/PATCH, SMS, and some accounting writes remain coarse (V-16, Partial).

## 5. Functional Requirements

| Module | Requirements |
|---|---|
| **Authentication and session** (FR-AUTH-01–10) | Username/password login with BCrypt hashes and generic `401` on failure; password policy ≥ 8 characters with a letter and a number; lockout after 5 failures for 15 minutes; 30-minute JWT and 30-minute front-end idle logout; SMS OTP for ADMIN/MANAGER when `REQUIRE_MFA=true` (5-minute TTL, 5 attempts, resend throttle; enrolment/recovery manual); server-side RBAC; ADMIN-only user/system administration; audit of successful and failed logins. |
| **Members and KYC** (FR-MEM-01–08) | Create/maintain members with unique member number, identity, contact, address, occupation, employer, status, and join date; next-of-kin and beneficiary records; KYC document metadata/attachments; membership applications with fees, approval, and conversion to member/share account; configurable custom fields; exit requests with checklist; dormancy policy and candidate reporting; search by name, member number, phone, and Fayda ID. |

| Module | Requirements |
|---|---|
| **Savings** (FR-SAV-01–06) | Products (mandatory, voluntary, holiday, fixed) with rates, minimum balance, notice period, fees, overdraft, lock-in, and GL mappings; atomic deposit/withdrawal posting to member balance, ledger, and GL; reject non-positive amounts, insufficient balance, and minimum-balance breach; monthly interest by daily-outstanding or minimum-balance method with balanced journals; maintenance/passbook fees; savings accounts, signatories, and status. |
| **Term/fixed savings — TFS** (FR-TFS-01–03) | Create deposits with principal, rate, term, dates, accrued interest, maturity value, and penalty; record maturity and early break with penalty and updated maturity value. Linked-account settlement is **not** automated by the current endpoint; upcoming/matured deposit reporting. |
| **Shares** (FR-SHR-01–05) | Share categories (price, availability, min/max, payment agreement); member share accounts; upgrade/downgrade requests with approval; transfers between members; dividend runs (surplus, statutory reserve, distributable, per-share amount); General Assembly resolutions and execution. |
| **Loans and credit** (FR-LN-01–11) | Loan products and origination; purpose, guarantors, collateral, repayment/reserve accounts, grace period; appraisal, scoring, committee decision, approval; reducing-balance, flat-rate, and straight-line schedules; disbursement and GL posting; repayment allocation and overdue status; classification and provision **computation** (GL posting of provision runs is not automated); restructuring, write-off, recovery, and auto-debit **assessment** (the run records Debited/Insufficient rows but does not move funds); collateral, guarantors, groups, committees; aging, delinquency, PAR, collection, disbursement, and loan-book reports. |
| **General ledger and finance** (FR-GL-01–07) | Chart of accounts with classes, hierarchy, category, normal side, debit/credit permissions, and currency; journal entries; GL posting rules with debit/credit validation; posting of savings, loan, share, fee, expense, and payment transactions; trial balance, balance sheet, income/expense, and financial reports. |
| **Expenses and fixed assets** (FR-EXP-01–03) | Expense categories and entries with GL posting and reversal; fixed assets with depreciation rate, branch, and GL links; straight-line depreciation. |
| **Cash operations** (FR-CASH-01–03) | Tills with opening, deposits, withdrawals, closing, expected balance, and variance; vault-to-teller, teller-to-vault, vault-to-bank, and petty-cash movements with approval status; vault and petty-cash records. |
| **Payments** (FR-PAY-01–04) | Deposit, withdrawal, transfer, adjustment, branch claim, mass transfer, and reversal with maker-checker; ledger posting and authorized reversal; cash/non-cash payment modes and role transaction limits; fund reservations. |
| **Check-off** (FR-CHK-01) | Import employer/month batches, match to members/loans, and report matched, unmatched, expected, received, and variance. |
| **Bank reconciliation** (FR-BNK-01–03) | Bank accounts with book balance; statement transactions; matching to book entries; reconciliation sessions with statement/book balance, difference, matched/unmatched counts, and completion status. |
| **Approvals** (FR-APR-01–02) | Pending queue with type, reference, summary, amount, initiator, and date; approve/reject by an authorized checker; exactly one decision wins under concurrency, others receive `409`. |
| **Day control** (FR-DAY-01–04) | System business date and per-branch COB; EOD step records. The current EOD run marks steps `Done` with placeholder counts and does **not** itself execute interest/fee/provision postings; business-date advance requires EOD status `Completed`; branch COB close/reopen. Per-step failure/retry handling is not implemented. |
| **Compliance** (FR-CMP-01–03) | Policy thresholds (minimum liquidity %, maximum large exposure %); liquidity, large-exposure, profit-allocation, and cash-flow views from live data; breach flagging. |
| **Audit trail** (FR-AUD-01–05) | Capture create/update/delete/login/approve/reject with actor, entity, entity ID, field, old/new value, IP, and timestamp; redact password/secret/token/API key; SHA-256 hash chain with `/api/audit-trail/verify`; database rejection of UPDATE/DELETE on `audit_trail` and `sms_log`; read access for ADMIN/MANAGER/AUDITOR. |

| Module | Requirements |
|---|---|
| **SMS and notifications** (FR-SMS-01–03, FR-NTF-01) | AfroMessage SMS using server-side credentials only; OTP and message logging; gateway status without exposing the API key; notification templates by event/channel and gateway settings. |
| **Referrals** (FR-REF-01) | Referral codes, records, qualification/reward, and conversion/reward reporting. |
| **System operations and admin** (FR-SYS-01–03) | ADMIN backups/cache/scheduler/health; branches, currencies, payment modes, holidays, organization profile, user groups, device-access records; member bulk import ( `POST /api/members/import` ). The Data Migration UI validates/previews rows but does not post to ledger/registry endpoints. |
| **Reporting and search** (FR-RPT-01–03, FR-DSH-01, FR-SRC-01) | Report catalog (financial, loan, head-office, savings, share, member, operational); parameters (date range, office, status, as-of); CSV/Excel and printable output; dashboard KPIs; global search across members, accounts, shares, GL, documents, transactions, and loans. |

## 6. External Interfaces

| Interface | Direction | Protocol / Format | Notes |
|---|---|---|---|
| Staff browser | Inbound | HTTPS, HTML/JS | React SPA; TLS terminated at the reverse proxy. |
| REST API | Inbound | HTTPS, JSON, JWT Bearer | `/api/**` ; JSON `401` / `403` ; CORS allowlist. |
| PostgreSQL | Outbound | JDBC; TLS recommended | Flyway migrations; append-only triggers. |
| AfroMessage SMS | Outbound | HTTPS/JSON, Bearer token | Server-side only; OTP and notifications. |
| File import/export | Both | CSV/XLSX/print | Reports, check-off, member import. |

No POS, card-reader, fiscal-printer, or payment-switch interface exists.

## 7. Non-Functional Requirements

| Category | Requirement |
|---|---|
| **Security** | Password authentication (BCrypt, no role-only login); MFA for privileged roles; 30-minute sessions and 5/15-minute lockout; server-side RBAC with least privilege; TLS 1.3 in production and mTLS for service links; encryption at rest and field encryption for Fayda ID/phone; HSTS, CSP, XFO, XCTO, Referrer-Policy, Permissions-Policy; CORS allowlist; secrets from a secret manager; generic errors with no stack traces. Current gaps: residual coarse authorization (PUT/PATCH/SMS), plaintext Fayda/phone, TLS template not deployed and mTLS absent (V-10, V-11, V-16). |
| **Performance** | Standard list/detail endpoints: average < 800 ms and p95 < 1,500 ms over 20 samples after warm-up on reference hardware; login average < 1,500 ms; capacity validated for at least 50 concurrent back-office users; reports over 30 seconds paginated or asynchronous. |
| **Availability** | Target 99.5% monthly excluding approved maintenance; daily full backup + WAL archiving; RPO ≤ 24 hours and RTO ≤ 4 hours until a HA/DR design is approved; encrypted off-site backups with quarterly restore tests; health endpoint for ADMIN. |

| Category | Requirement |
|---|---|
| **Maintainability** | Layered Spring components; forward-only Flyway migrations; TypeScript/React front end; automated tests for auth, RBAC, financial calculations, approvals, audit, and reports; structured centralized logs without secrets/PII; externalized configuration; same artifact across environments. |
| **Compliance** | Support applicable INSA OF/AEAD/001 evidence; retain audit records per the SACCO's legal schedule; do not store card data (reduced PCI scope); do not claim fiscal-invoice compliance unless certified. |
| **Usability** | Usable at 1280×720 and above; English and Amharic labels; confirmation for destructive actions; approvals show maker, amount, and reference. |

## 8. Constraints

1. Web-only back office; no device, firmware, POS, invoice, or card-reader functionality.
2. PostgreSQL is required for triggers, `TIMESTAMPTZ`, and Flyway migrations.
3. TLS and encryption at rest are deployment responsibilities; a TLS 1.3 nginx template is provided (`deploy/nginx-cbs.conf.template`) but not deployed. The app supports HSTS and HTTPS redirect but does not terminate TLS or encrypt volumes.
4. SMS MFA depends on AfroMessage; a break-glass procedure is required if the gateway is unavailable.
5. JWT is stateless; logout is client-side and server-side revocation is not implemented.
6. Single-tenant deployment; no tenant isolation.
7. Some workflows are demonstrative: EOD steps, auto-debit, term-deposit settlement, and the Data Migration UI do not execute all downstream postings. These must be completed before production use.
8. The legacy test harness still assumes passwordless login and must be updated before CI can be release evidence.

## 9. Acceptance Criteria

| ID | Criterion |
|---|---|
| AC-01 | Valid username/password returns a JWT; missing or wrong password returns `401`. |
| AC-02 | ADMIN/MANAGER with MFA enabled receives `202 mfaRequired` and completes login with a valid OTP; TELLER does not require MFA. |
| AC-03 | Five failed attempts lock the account for 15 minutes (`423`) and the event is audited. |
| AC-04 | TELLER/MANAGER cannot read `/api/auth/users`; AUDITOR cannot write; unauthenticated calls return `401`; admin-only paths return `403` for non-admins. |
| AC-05 | Negative or over-balance savings transactions return `400` with no ledger change. |
| AC-06 | A loan approval is decided exactly once under concurrent approvers; other attempts return `409`. |

| ID | Criterion |
|---|---|
| AC-07 | Business date cannot advance until EOD is `Completed`; duplicate EOD runs are rejected. |
| AC-08 | Audit trail verifies as `valid`; direct UPDATE/DELETE on `audit_trail` / `sms_log` is rejected. |
| AC-09 | Security headers are present; disallowed CORS origins receive no ACAO. |
| AC-10 | No stack trace or internal path appears in an error response. |
| AC-11 | `npm audit --omit=dev` reports 0 vulnerabilities and no ProComponents/ProLayout packages remain. |
| AC-12 | Production uses TLS 1.3, encrypted volumes, a secret manager, and the production credential guard with no default/demo credentials (currently partial/open: V-10, V-11, V-15). |

## 10. Traceability

| Requirement group | Audit reference |
|---|---|
| Authentication, MFA, session, lockout | INSA 7, 7.1; V-01, V-04, V-09, V-14, V-15 |
| RBAC and role separation | INSA 7.2, 10.2, 12.2; V-03, V-16 |
| Audit trail | INSA 11 (analogue), 16; V-08, V-19 |
| Secure communication | INSA 6, 6.1, 6.2, 12; V-10 |
| Data protection | INSA 5, 5.1, 5.2; V-11 |
| Input validation / API security | INSA 12.1, 14.2; V-17 |
| Pen testing / certification | INSA 14, 15, 16.2; V-12, V-13 |
| Device/firmware/fiscal items | INSA 2–4, 8–11, 13; **Not Applicable** (no device) |

*End of specification.*